

TEMASEK POLYTECHNIC

SCHOOL OF INFORMATICS & IT

**Diploma in Cybersecurity & Digital Forensics
AY 2026/2027 CASE STUDY (40%)**

(April Semester)

ETHICAL HACKING AND INTRUSION PREVENTION (CCD2C03)

TIME ALLOWED: REFER TO TEACHING PLAN

INSTRUCTIONS TO CANDIDATES

1. This assignment consists of 11 pages (including cover page)
2. This assignment consists of 2 components:
 - a. Penetration Test Report – 30% (Individual)
 - b. Presentation – 10% (Individual)

Report Submission Deadline	Week 15 — 27 Jul 2026, Monday, 0830hrs
Presentation	Week 15 to Week 16 — In-Class (Scheduled Slot)
Group Size	4–5 students per group
Submission Format	PDF via POLITEMall

1. Assessment Overview

1.1 Scenario Background

You have been engaged as a junior penetration testing consultant by SecureEdge Pte Ltd, a cybersecurity firm contracted to assess the security posture of MedPharm Logistics, a mid-sized pharmaceutical supply chain company operating in Singapore.

MedPharm Logistics recently migrated part of its infrastructure to a hybrid environment: some legacy systems remain on-premise while customer-facing services were moved to a cloud-hosted environment. The company has reported anomalous network activity and fears a potential breach. Your team has been given written authorisation (Rules of Engagement document provided separately) to conduct a full penetration test against the defined target scope.

1.2 Learning Objectives

Upon completing this assessment, students will be able to:

- Conduct a structured penetration test following the industry-standard methodology (Reconnaissance → Scanning → Exploitation → Post-Exploitation → Reporting).
- Identify and document vulnerabilities across web application, network, and system layers.
- Calculate and justify CVSS v3.1 Base Scores for each finding using the official scoring rubric.
- Produce a professional penetration testing report that meets industry standards (PTES / OWASP Testing Guide).
- Develop actionable, risk-prioritised remediation recommendations.
- Articulate technical findings clearly to both technical and non-technical audiences during a presentation.
- Apply ethical and legal considerations in conducting security assessments.

1.3 Scope of Work

Students are to form **groups of 4 to 5** for this assessment. The main objective for all groups is to perform a penetration test on one of the target machines.

- a. Each target is configured with 2 levels of challenges. The first level challenge will require you to perform the initial exploitation and the second level challenge will require you to perform privilege escalation to gain root access.
- b. Each student in the group is to do a write-up on **ONE** of the target machines (initial entry **OR** privilege escalation **OR** both). Template for the writeup is provided in POLITEMall.

All members in the same group are to write on a **unique target machine.**

- c. More marks will be awarded for **successfully exploiting both levels of challenges** due to the effort and complexity of the second level challenge.

2. Assessment Requirements (Individual)

2.1 Deliverable 1 - Penetration Testing Report

Each group must produce one professional penetration testing report. The report must follow the structure below and be written to a professional standard suitable for delivery to a client. All screenshots must be annotated.

Required Report Structure

#	Section	Required Content
1	Executive Summary	High-level overview for non-technical stakeholders. Business impact statement. Overall risk rating. Top 3 critical findings. Engagement scope and dates.
2	Scope & Rules of Engagement	Defined IP ranges and URLs in scope. Exclusions. Testing window. Emergency contact procedures. Written authorisation reference.
3	Methodology	Pentest phases followed (Recon, Scan, Exploit, Post-Exploit). Standards referenced (PTES, OWASP, NIST). Tools used per phase.
4	Findings Summary Table	All findings listed with: ID, title, CVSS score, severity, affected host, and status (Open/Mitigated).
5	Detailed Findings	One subsection per vulnerability. Must include: description, evidence (screenshots), CVSS v3.1 vector string, impact, and recommendation.
6	CVSS Calculations	Full CVSS v3.1 metric breakdown for each finding. Base score justification. Temporal and Environmental scores (where applicable).
7	Remediation Roadmap	Prioritised remediation plan with short-, medium- and long-term actions. Effort estimate (Low / Medium / High). Owner assignment (suggested roles).
8	Appendices	Raw tool outputs. Network diagrams. Vulnerability scanner reports. Glossary of terms.

2.2 Deliverable 2 – CVSS v3.1 Calculations

For every vulnerability discovered, students must perform a full CVSS v3.1 Base Score calculation. All vulnerabilities discovered must be documented.

CVSS v3.1 Base Metric Groups

Group	Metric	Options	Guidance
Exploitability	Attack Vector (AV)	N / A / L / P	Network, Adjacent, Local, Physical

Group	Metric	Options	Guidance
	Attack Complexity (AC)	L / H	Low or High complexity to exploit
	Privileges Required (PR)	N / L / H	None, Low, or High privilege needed
Scope	User Interaction (UI)	N / R	None or Required
	Scope (S)	U / C	Unchanged or Changed
Impact	Confidentiality (C)	N / L / H	None, Low, or High impact on confidentiality
	Integrity (I)	N / L / H	None, Low, or High impact on integrity
	Availability (A)	N / L / H	None, Low, or High impact on availability

CVSS Severity Ratings

None	Low	Medium	High	Critical
0.0	0.1 – 3.9	4.0 – 6.9	7.0 – 8.9	9.0 – 10.0

3. Presentation Requirements (Individual)

Each group will present their findings during a 20-minute session followed by a 10-minute Q&A with the assessor(s). The presentation must demonstrate that every group member understands the technical content.

3.1 Presentation Structure

Slot	Content	Duration	Who Presents
1	Introduction: Scope, methodology, team roles	3 min	All members briefly
2	Top 2 critical findings: live demo or recorded walkthrough	8 min	Assigned member(s)
3	CVSS walkthrough: justify one finding's score metric by metric	4 min	Assigned member
4	Remediation roadmap & business impact summary	5 min	Assigned member
Q & A	Assessor questions — each member may be asked individually	10 min	All members

3.2 Justification Expectation

During both the presentation and Q&A, students are expected to justify their findings. Assessors will probe with questions such as:

- "Why did you assign Attack Complexity: Low for this finding?"
- "What would change in your CVSS score if the server were behind a load balancer with no direct internet access?"
- "Your report recommends patching. Why not simply block the port instead? What are the trade-offs?"
- "How did you confirm this vulnerability was actually exploitable, not just reported by the scanner?"
- "What is the business impact of this finding for MedPharm's pharmaceutical supply chain operations?"

Inability to answer questions about your own findings will result in significant mark deductions. Do note that the above list of questions are some examples of questions you may encounter during the Q&A.

4. Marking Rubric

4.1 Penetration Testing Report (15 marks)

Criterion	Marks	Distinction (80–100%)	Merit (70–79%)	Pass (50–69%)	Fail (< 50%)
Executive Summary & Scope	3	Concise, accurate, C-suite ready. Clear business impact. Scope fully documented.	Mostly clear. Minor gaps in business impact language.	Adequate but overly technical or incomplete scope.	Missing or inaccurate. Not client-ready.
Methodology & Tools	3	Named phases, tools, and standards. Logical flow. Limitations acknowledged.	Phases and tools listed. Minor gaps in standards reference.	Partial methodology. Some tools listed.	Missing methodology or generic placeholder text.
Findings Documentation Quality	3	All findings: full description, annotated PoC, impact, remediation. Professional tone.	Most findings well-documented. Some screenshots lack annotation.	Basic documentation. Missing evidence or impact for some findings.	Incomplete or copy-pasted scanner output with no analysis.
Writing & Professionalism	3	Publication-ready. Consistent formatting, no errors, client-appropriate language.	Minor grammatical issues. Generally professional.	Readable but inconsistent formatting or informal language.	Poor grammar, inconsistent format, or missing sections.
Appendices & Evidence	3	Complete raw outputs, annotated. Network diagram included. Glossary present.	Raw outputs included. Minor gaps (e.g., no glossary).	Some tool outputs present. No diagram.	Missing or irrelevant appendices.
Section Total:		15 marks			

4.2 CVSS Calculation (15 marks)

Criterion	Marks	Distinction (80–100%)	Merit (70–79%)	Pass (50–69%)	Fail (< 50%)
Metric Selection Accuracy	7	All 8 base metrics correct for every finding. Vector strings validate against CVSS calculator.	1–2 metric errors across all findings. Self-corrected in justification.	3–4 metric errors. Scores slightly off but reasoning partially correct.	Significant metric errors. Scores substantially wrong.
Justification Depth	8	Every metric justified with scenario-specific reasoning. Real-world attacker perspective.	Most metrics justified. Some generic or textbook explanations.	Basic justifications. Limited connection to actual findings.	No justifications, or justifications copied from CVE database.
Section Total:		15 marks			

4.3 Presentation (10 marks)

Criterion	Marks	Distinction (85–100%)	Merit (70–84%)	Pass (50–69%)	Fail (< 50%)
Technical Accuracy	4	All technical claims correct. No errors under Q&A probing. Demonstrates deep understanding.	Minor inaccuracies; self-corrected during Q&A.	Some inaccuracies but core concepts understood.	Significant technical errors; cannot answer basic Q&A.

Justification of Findings	3	Every claim justified with evidence + reasoning. Contextualise s to MedPharm business risk.	Most claims justified. Limited business context.	Some claims unjustified or relies on scanner output only.	Cannot justify findings; reads off slides without understanding.
Communication Clarity	3	Clear, confident, audience-appropriate. Technical terms explained. No filler reading.	Generally clear. Occasional over-reliance on notes.	Adequate but heavy reliance on notes or technical jargon unexplained.	Unclear delivery; difficult to follow; reads from screen.
Section Total:		10 marks			

TOTAL ASSESSMENT MARKS:
40 marks (40% of Module Grade)

Breakdown: Report (15 marks) + CVSS (15 marks) + Presentation (10 marks) = 40 marks

5. Academic Integrity & Submission Requirements

5.1 Academic Integrity

- a. All findings must be genuinely discovered by your group during the assessment period.
- b. You may use CVE databases and OWASP references to understand vulnerabilities, but your report content and analysis must be your own work.
- c. Sharing of specific findings, CVSS calculations, or report sections between groups is considered plagiarism.
- d. Use of AI tools (ChatGPT, etc.) to generate report content is prohibited. You may use AI for grammar checking only.

5.2 Ethical Conduct

You are NOT to perform vulnerability assessments and penetration tests beyond the scope given, such as scanning other networks and systems. Anyone caught doing so could result in **immediate failure of this subject or even more severe disciplinary action.**

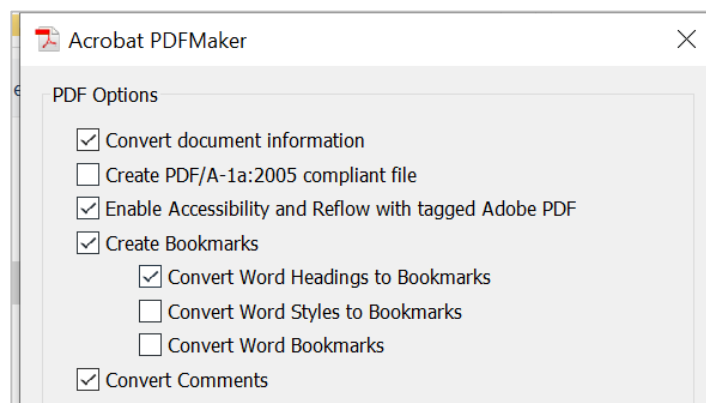
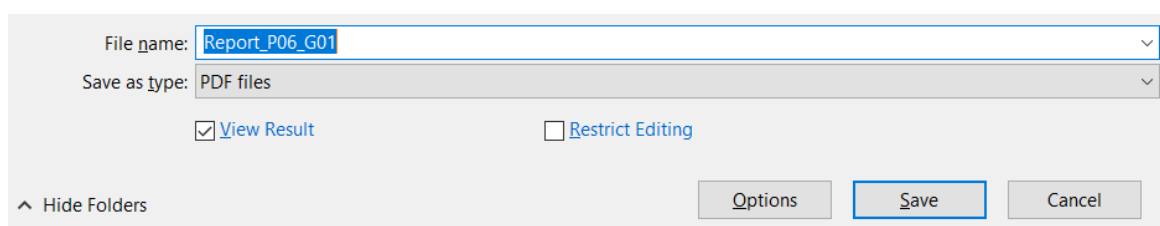
5.3 AI Tool Usage Guidelines

- a. Use **AI tools ethically** and document how they were used:
 - Which AI tool(s) you used
 - How you used it (e.g., structuring ideas, debugging scripts)
- b. Critically evaluate and reflect on the accuracy and usefulness of AI support.
- c. Students may use AI for:
 - Brainstorming and planning testing strategies
 - Clarifying technical concepts
 - Structuring and editing the report
 - Suggesting exploit techniques (to be tested and verified manually)
 - Debugging scripts (e.g., Bash, Python)
 - Providing feedback or summarizing documentation
- d. Do NOT use AI for:
 - Fabricating or simulating test results
 - Submitting content without critical review or personal understanding
 - Sharing AI-generated answers without verification

5.4 Submission Requirements

- a. All groups are to submit a combined report that contains the following:
 - Cover Page
 - Declaration of Originality (with complete signatures)
 - Executive Summary
 - Findings Overview
 - Detailed Findings and Recommendations (compiled finding writeups written by all 4-5 members)

- b. For the title of each finding, you are only allowed to use ONE title per vulnerability. Here are some examples of accepted titles:
- Misconfigured Scheduled Task Permissions
 - Weak/Known Password of User Account ' _____ '
 - Misconfigured Sudo Privileges
 - Default/Weak Administrator Password
 - SQL Injection
 - Cross-Site Scripting (Stored)
- c. For more information regarding the various sections of the report template, view the comments for more information.
- d. You are expected to submit the Final Report as a PDF document with all the necessary requirements listed 1.3(a). To generate the PDF file, follow the instructions below:
- Open your Word document and go to **File > Save as Adobe PDF**
 - Once done, go to **Options** and ensure that you tick the following boxes:
 - i. Create Bookmarks
 - ii. Convert Word Headings to Bookmarks



- e. **Be warned that plagiarism is a serious offence!**

Students are to submit via Brightspace LMS based on the stipulated deadline specified in the Teaching Plan. **Submissions via any other communication channels (e.g Emails, WhatsApp, Microsoft Teams) will not be accepted.**

Late submissions:

- a. Late and < 1 day: 10% deduction from absolute mark given for the assignment. E.g., 75 marks (100 marks max) → 65 marks (10% of 100 marks).

- b. Late ≥ 1 and < 2 days: 20% deduction from the absolute mark.
- c. Late ≥ 2 days: No marks awarded.